



[internal-portal-public] [http] [low] <https://airflow.>

[internal-portal-public] [http] [low] <https://openvpn.>

[internal-portal-public] [http] [low] <https://vca-admin.>

[internal-portal-public] [http] [low] <https://admin-int.>

[internal-portal-public] [http] [low] <https://airflow-d.>

[internal-portal-public] [http] [low] <https://ims.>

[default-admin-creds-ims] [http] [Critical]

<https://ims.> /SapphireIMS/LoginPage.do

I       

message #nuclei-alerts

February 23, 2024

How Automation Detected Default Admin Credential Worth \$500

FREE ARTICLE LINK 



By the_unlucky_guy

2 min read

[Download article](#) 

Hello hackers, I am back with a new bug bounty write-up. In this blog, I am going to show how my automation discovered default admin credentials in the company's internal IT portal — **Sapphire IMS**. The company has a bug bounty program on **Hackerone**. I will be using **redacted.com** as the main domain.

***redacted.com** is in the scope. As usual, I started with subdomain enumeration and found approximately 70 subdomains out of which only 30 are reachable. I already spent a few days on this program and submitted a few IDOR and access control bugs on the main domain.

There are 10 subdomains that are not reachable, but their names are **airflow.redacted.com**, **ims.redacted.com**, etc. It seems that there is some internal portal running on them, and I assume that access to the portal is limited to VPN/Office IPs.

I assumed below test cases for all the internal portal:

1. The portal is unauthenticated
2. The portal is authenticated

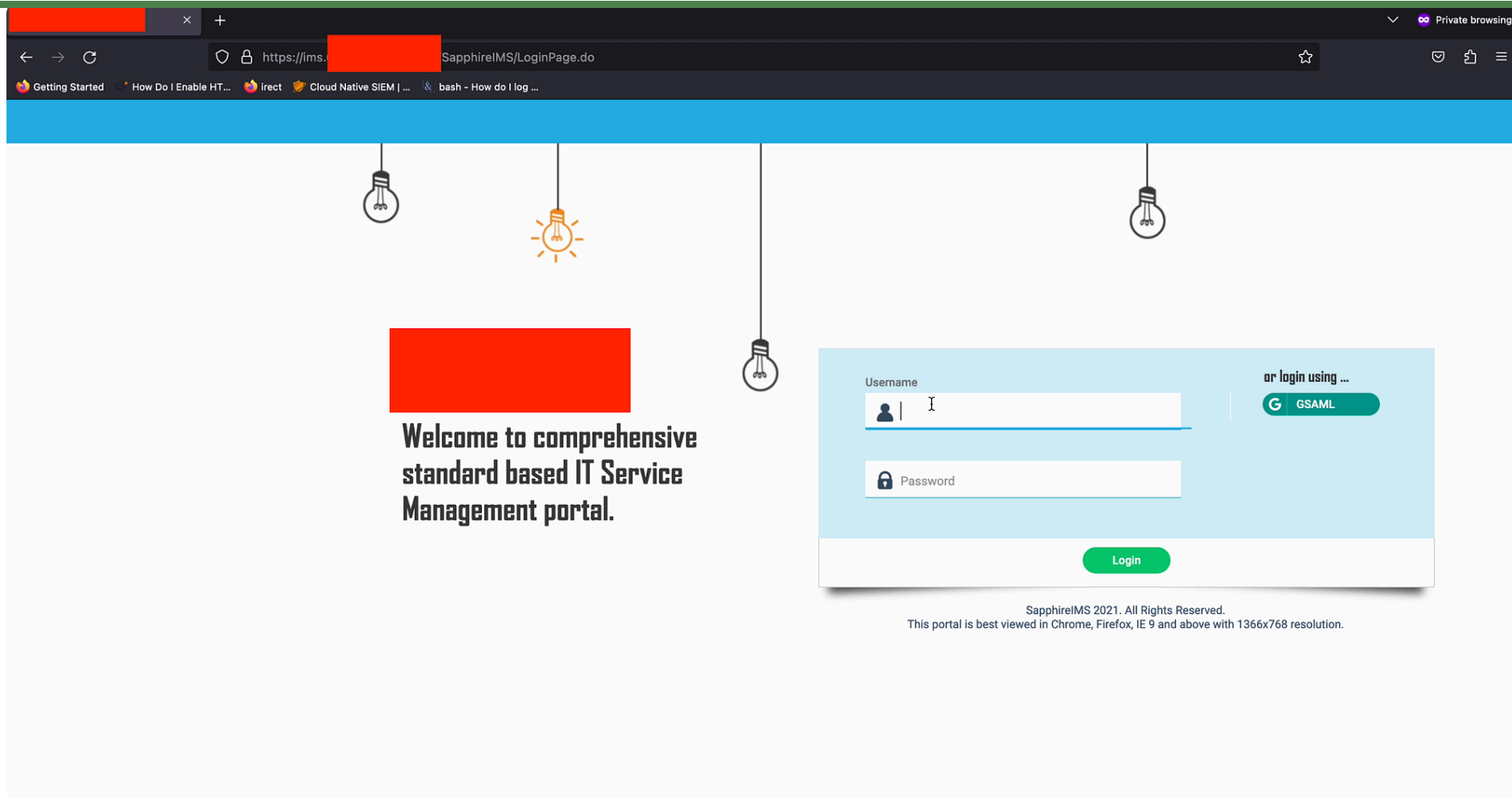
3. The portal may have a default login credential

Based on that, I assume that there is a possibility in the future that, by mistake, all the portals will be made public by the developer. Relying on my prediction, I added these subdomains to my automation. My automation runs every 10 minutes. I use some community-created and some custom nuclei templates to automatically scan the subdomains for default credentials. I will get a Slack alert if the portal is publicly accessible and has default login credentials.

After **3 Months**, I receive a slack alert

```
[internal-portal-public] [http] [ low] https://airflow.[redacted]
[internal-portal-public] [http] [ low] https://openvpn.[redacted]
[internal-portal-public] [http] [ low] https://vca-admin.[redacted]
[internal-portal-public] [http] [ low] https://admin-int[redacted]
[internal-portal-public] [http] [ low] https://airflow-d[redacted]n
[internal-portal-public] [http] [ low] https://ims.[redacted]
[default-admin-creds-ims] [http] [ Critical]
https://ims.[redacted]/SapphireIMS/LoginPage.do
```

And yeah, my prediction was correct. The developer did make a mistake and made all the portals publicly accessible. Among them, one subdomain, **ims.redacted.com**, is running the IT portal **Sapphire IMS** and has default admin login credentials.



I manually re-verified the default admin credentials, and I successfully logged into the portal as an admin. I quickly reported this issue to the security team through **Hackerone**. The Company fixed the issue and rewarded a bounty of \$500.

Participants



Reported to



Report Id

#21

Resolved
(Closed)

Severity

Medium (4 ~ 6.9)

Asset: Dom...



Generic

Time spent

1h



Do check out [Nuclei](#). If you don't know about it then you are missing something fantastic.

Timeline:

September 07, 2023 — Reported

September 07, 2023 — Fixed

October 11, 2023 — \$500 Bounty awarded.

To schedule a one-on-one session with me, please make a booking through the Topmate platform.

Thanks for reading, hope you learned something new. Do clap and share if you like. Happy Hacking!

Twitter: [7he_unlucky_guy](#) LinkedIn: [Vijeta](#) Topmate: [Vijeta](#)

